信息安全测评与风险评估

6.3 编制完整等保测评报告

授课教师：张玉



目录

CONTENTS

01 案例导入——“一份差评报告引发的信任危机”

02 学习目标

03 等保测评报告——在测评工作中的定位

04 等保测评报告的规范格式

案例导入——“一份差评报告引发的信任危机”



思考：一堆记录表，怎么变成专业的测评报告？

机构问题：现场认真记录，但提交的报告存在：

- **格式混乱**
  缺公章、页码错乱、字体不一
- **结论模糊**
  判定依据不足，前后矛盾
- **描述笼统**
  无具体问题描述和风险分析
- **建议空洞**
  缺乏实操性，如“加强管理”

结果：客户拒付尾款，列入黑名单。

问题讨论

- 这份报告存在哪些问题？好报告应具备什么特征？
- 报告质量反映了团队什么能力？

学习目标

通过本课学习，你将能够：

理解	等保测评报告的规范格式与编制要求
掌握	单项测评结论的判定方法（符合/部分符合/不符合/不适用）
掌握	系统整体测评结论的形成方法
能够	撰写具体、可操作的整改建议
能够	独立编制一份完整的等保测评报告

等保测评报告——在测评工作中的定位

测评报告是测评工作的**“最终产品”**，是测评师专业能力的**“最终证明”**。

测评报告的三重价值：

维度	价值	受益方
法律价值	公安机关监督检查的法定依据	监管部门、测评机构
决策价值	帮助客户了解安全现状、做出整改决策	客户管理层
技术价值	指导客户开展安全整改	客户技术团队

等保测评报告的规范格式（15分钟）

标准报告结构（十要素）：

素材1：测评报告模板（结构框架）.d

序号	组成部分	核心内容
1	封面	报告名称、被测系统名称、委托单位、测评机构、报告日期、版本号
2	目录	自动生成、页码准确
3	项目概述	项目背景、测评目的、测评范围、测评依据
4	测评对象与方法	测评对象清单、采用的测评方法（访谈/核查/测试）
5	单项测评结论	逐项判定，含指标编号、名称、结果、问题描述
6	系统整体测评结论	汇总分析、符合性判断、风险趋势
7	安全问题汇总	按风险等级汇总所有问题
8	整改建议	针对每个问题的具体整改措施
9	附件	测评证据索引、记录表附件
10	签章页	测评人员签名、机构盖章

格式规范要点

要素	规范要求	常见错误
字体	正文宋体/仿宋，标题黑体，统一字号	多种字体混用 ✗
页码	从正文开始编页码，封面不编号	页码混乱或缺失 ✗
表格	统一边框、表头加粗、编号连续	表格格式不一致 ✗
编号	章节编号层级清晰（1→1.1→1.1.1）	编号跳跃或层级混乱 ✗
引用	标准条款标注编号（如8.1.2.1 a)）	只写条款不写编号 ✗

教师演示——报告模板使用

演示步骤：

1. **打开报告模板**
   查看完整结构
2. **填写封面信息**
   项目名称、日期、版本
3. **填充项目概述**
   从测评方案复制相关内容
4. **导入测评记录**
   将前序项目的记录表内容填入
5. **生成单项结论**
   逐项判定并填写
6. **撰写整体结论**
   汇总分析、形成判断
7. **编写整改建议**
   具体、可操作
8. **生成目录与签章**
   自动生成目录、签字盖章

单项测评结论判定（四象限法）

符合 绿色

完全满足标准要求

所有子项均满足



部分符合 黄色

部分满足，存在差距

关键子项满足，非关键子项有不足



不符合 红色

不满足标准要求

关键子项不满足或整体差距较大



不适用 白色

系统不涉及该项

需说明理由（如“系统无无线网络”）



判定原则

- **符合≠** “大概可以”——必须有证据支持
- **不符合≠** 否定全部——说明哪些不满足
- **部分符合≠** 回避问题——必须说明具体不足
- **不适用≠** 随意使用——必须有充分理由

单项结论判定实例

示例场景： 某三级系统的主机安全核查——身份鉴别

检查项	标准要求（8.1.4.1）	实际情况	判定
a)	身份标识唯一，口令复杂度并定期更换	口令长度8位，含大小写+数字，90天更换	符合
b)	登录失败处理功能，限制非法登录次数	连续失败5次锁定15分钟	符合
c)	远程管理防止鉴别信息被窃听	使用SSH加密管理	符合
d)	两种以上鉴别技术，其中一种为密码技术	仅口令一种，无双因素认证	不符合

总体判定： 8.1.4.1 身份鉴别 →不符合

判定依据： 关键条款d）不满足——三级系统要求双因素认证，但系统当前仅使用口令单因素认证。

单项结论判定的常见错误

✕ 错误做法	☑ 正确做法
“防火墙配置基本符合要求，建议加强”——模糊	“防火墙策略中Rule 10允许任意IP访问22端口，不符合8.1.3.2 c)”——具体
多项子项不满足仍判“部分符合”	关键子项不满足应判“不符合”
不适用项不说明理由	标注“系统无无线网络，不适用”+理由
凭感觉判定，不引用标准条款	每条判定引用GB/T 22239具体条款编号

系统整体测评结论的形成

整体结论 = 对所有单项结论的汇总分析

形成步骤：

1 统计各等级结论的数量

符合X项、部分符合X项、不符合X项、不适用X项

2 分析不符合项分布

哪些维度问题集中？技术 vs 管理？

3 评估风险影响

哪些问题影响核心业务？哪些是致命缺陷？

4 形成整体判断

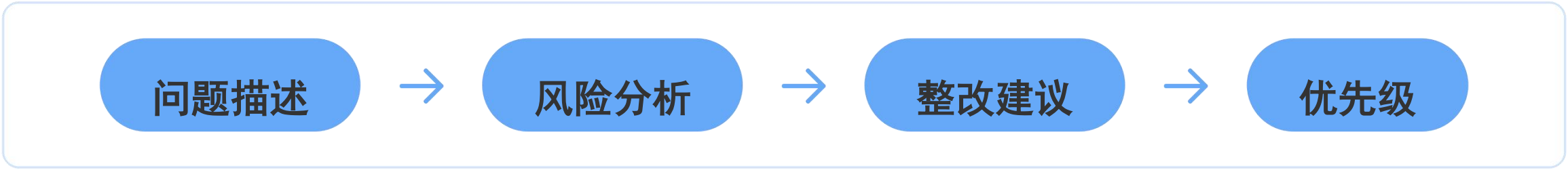
符合 / 基本符合 / 不符合

系统整体测评结论的判断标准

三级判定标准：

整体结论	判定标准	示例
符合	所有指标均为“符合”	极少见，通常出现在已通过测评的系统中
基本符合	存在“部分符合”或“不符合”项，但无重大安全隐患	大部分指标符合，个别管理类指标有差距
不符合	存在重大安全隐患（如高危漏洞、核心指标不满足）	存在可被利用的高危漏洞、关键设备无冗余、未实现双因素认证

安全整改建议的撰写方法



要素	要求	示例
问题描述	具体、准确、可验证	经核查，核心交换机为单台部署，未配置备用设备
风险分析	说明安全影响	核心交换机单点故障将导致全网业务中断
整改建议	具体、可操作	建议增配一台核心交换机，实施双机热备
优先级	紧急/高/中/低	高（3天内完成）

好建议 vs 差建议对比



素材4：整改建议示例（完整版）.do

差建议

“建议加强密码管理”

好建议

“经核查，Windows服务器未启用口令复杂度策略。建议：在组策略中启用‘密码必须符合复杂性要求’，设置最小长度为8位，启用‘强制密码历史’为5个，10个工作日内完成。”

差建议

“建议及时更新补丁”

好建议

“系统存在Apache Struts2远程代码执行漏洞（CVE-2017-5638）。建议：升级Struts2至2.5.22或更高版本；部署WAF拦截恶意请求；7天内完成。”

差建议

“建议完善安全管理制度”

好建议

“安全管理制度中缺少《安全事件报告与处置管理制度》。建议：参照GB/T 22239 8.1.10.12要求，制定并发布该制度，明确事件报告流程和处置职责。”

整改优先级划分原则

优先级	适用情形	建议时限	标记
紧急	存在可直接利用的高危漏洞、核心系统无防护	24–48小时	
高	重要配置缺陷、中危漏洞、核心功能缺失	3–7天	
中	一般配置问题、低危漏洞、管理文档缺失	7–30天	
低	优化建议、非关键项	30–90天	

实践任务——编制完整等保测评报告（45分钟）

要素	内容
任务名称	依据前序项目材料编制一份完整的等保测评报告
任务场景	教师提供前序项目的全部测评记录（模拟数据）
任务内容	依据报告模板编制完整报告逐项填写单项测评结论形成系统整体测评结论撰写整改建议自查格式规范

提供的素材：

1. 测评报告模板（Word版）



素材2：前序项目
测评记录表（模拟数

2. 前序项目全部测评记录表（模拟数据）



素材3：模拟系统
基本信息.docx

3. 测评方案（含系统基本信息）

实践任务——报告编制自查清单

提交前逐项自查：

检查项	是/否
封面信息完整（项目名称、日期、版本）	☐
目录自动生成、页码准确	☐
项目概述包含背景、目的、依据	☐
所有测评记录已填入单项结论	☐
单项结论判定有标准依据	☐
整体结论客观、有数据支撑	☐

思政融入——测评报告中的职业品格

一份测评报告，就是测评师的一张“职业名片”。



客观

报告不是给客户“交差”的文书，而是安全状况的真实反映

不隐瞒重大风险，不夸大安全问题



专业

每一份报告都代表测评机构的专业水平

格式规范、结论准确、建议可行



负责

报告内容可能影响客户的安全决策

一份不负责任的报告，可能导致客户忽视重大风险

一句话： 测评报告的字里行间，体现的是测评师的责任与担当。

– 知识点回顾（5分钟）：思维导图

编制完整等保测评报告

一、报告格式

- 封面、目录、项目概述
- 测评对象与方法
- 单项/系统整体测评结论
- 安全问题汇总、建议
- 附件、签章页

二、单项结论判定

- **结论：** 符合/部分符合/不符合/不适用
- **依据：** 标准条款 + 证据
- **避坑：** 模糊、不引用标准

三、整体结论形成

统计 → 分析 → 判断

✦ **评判层级：** 符合 / 基本符合 / 不符合

四、整改建议撰写

1. **逻辑结构：** 问题→风险→建议→优先级
2. **核心原则：** 具体、可操作、有时限

课后作业

必做 完成一份完整的等保测评报告（基于课堂提供的模拟数据），提交至学习通平台

必做 完成项目6.3在线测试（选择题+判断题，共20题）

选做 选取真实测评报告（脱敏版），分析其优点与可改进之处

预习 预习期中考试内容

下节课预告

期中考试

考试形式

- 理论考核
- 闭卷上机，90分钟

考试范围

- 等保2.0标准体系
- 安全通用要求（物理环境、通信网络、区域边界、计算环境、安全管理）
- 测评流程与方案编制

复习建议

- 回顾项目1-6的知识点
- 复习测评记录表和报告模板